Ders 4 Çalışma Özeti

Ders 4 Çalışma Özeti

Genel Konular

- Güvenli tasarım ilkelerine giriş
  - Hataların tamamen ortadan kaldırılamayacağı kabul edilerek zafiyetlerin etkisini sınırlandıracak kurallar ele alınır.
  - Tehdit modelini bilmek, hangi saldırıların nasıl gerçekleşebileceğini anlamak için temel gerekliliktir.
- Defense in depth
  - Tek bir savunma mekanizması yerine farklı katmanlarda birbirini tamamlayan mekanizmalar kullanılmalıdır.
  - Tarayıcı sekmesi izolasyonu, işletim sistemi proses izolasyonu, firmware koruması ve ağ içi yayılım engelleme aynı saldırıya karşı farklı katmanlardaki örneklerdir.
- Least privilege
  - Bir öznenin görevini yerine getirebilmesi için gereken minimum yetki, aynı zamanda sahip olması gereken maksimum yetkiyi tanımlar.
  - Gereğinden fazla yetki, hata, kötü niyet veya sistem ele geçirilmesi durumunda zararı büyütür.
- Privilege separation
  - Sistem, farklı yetki gereksinimlerine sahip bileşenlere ayrılmalıdır.
  - Bir bileşenin ele geçirilmesi saldırganın tüm sistemi ele geçirmesini engelleyecek şekilde sınırlandırılmalıdır.
- Subject, object, operation modeli
  - Güvenlik kuralları; işlemi yapan özne, üzerinde işlem yapılan nesne ve gerçekleştirilen operasyon üçlüsüyle ifade edilir.
  - Kullanıcı, proses, uygulama, domain veya cihaz subject olabilir; dosya, bellek, cookie, donanım ve ağ kaynağı object olabilir.

Hocanın Özellikle Vurguladığı Kısımlar

- Tek hat savunması yeterli değildir
  - Farklı katmanlarda bağımsız ama tamamlayıcı savunma gerekir.
- Minimum yetki maksimum yetkidir
  - Görev için gerekmeyen hiçbir yetki verilmemelidir.
- Privilege separation saldırıyı hapseder
  - Bir modül ele geçirilse bile diğer modüllere geçiş engellenebilir.
- Subject-object-operation üçlüsü güvenlik analizinin temelidir
  - Bir ihlalde hangi öznenin, hangi nesne üzerinde, hangi işlemi hatalı yapabildiği sorulmalıdır.

Kısa Tekrar Notları

- Defense in depth: çok katmanlı savunma.
- Least privilege: gereken minimum yetkiyle çalışma.
- Privilege separation: yetki alanlarını bileşenlere ayırma.
- Subject işlemi yapan varlıktır.
- Object işlem yapılan kaynaktır.
- Operation read, write, execute gibi işlemdir.

Detaylı Açıklamalar

- Python gibi type-safe dillerde bile alt katmanda C ile yazılmış modüller bulunabilir. Python zipimport örneği, negatif veri boyutu üzerinden integer overflow ve heap tabanlı buffer overflow oluşabileceğini gösterir. Bu nedenle güvenli dil seçimi önemli olsa da tek başına yeterli kabul edilmez.
- Defense in depth yaklaşımı, bir zafiyet başarılı olsa bile zararın yayılmasını engellemeyi hedefler. Chrome örneğinde JavaScript yorumlayıcıdaki hata tek sekmeyle sınırlanmalı, işletim sistemi diğer proseslere erişimi engellemeli, donanım firmware kalıcılığını önlemeli ve ağ katmanı zararlının komşu sistemlere yayılmasını durdurmalıdır.
- Least privilege, kullanıcıdan uygulamaya, prosesten domaine kadar her özne için geçerlidir. Örneğin bir domain yalnızca kendi cookie değerlerini okuyabilmelidir; bir uygulama başka uygulamanın verisini değiştirememelidir; bir proses başka prosesin belleğini okuyamamalıdır.
- Unix güvenlik modelinde subject olarak kullanıcılar ve prosesler, object olarak dosyalar ve dosya gibi temsil edilen kaynaklar, operation olarak read, write ve execute kullanılır. Bu model daha sonraki erişim kontrol mekanizmalarının temelini oluşturur.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.